

Phoenix Cyber Resilience Project

CY020 – Compliance Documentation Framework

Prepared by: **Dilano**

Role: **Governance & Compliance Lead**

Unit: **SIT374 / SIT764 – Team Project A**

Institution: Deakin University

Date: May 2026

TABLE OF CONTENTS

1. Introduction
2. Purpose of Compliance Documentation
3. Governance & Compliance Objectives
4. Cyber Security Policies
5. Regulatory & Standards Alignment
6. Risk Assessment Process
7. Audit & Monitoring Procedures
8. Incident Response Compliance
9. Staff Roles & Responsibilities
10. Documentation Management
11. Recommendations
12. Conclusion

1. INTRODUCTION

Cybersecurity governance and compliance play an important role in ensuring that organisations operate securely, responsibly, and according to recognised standards and regulations. As cyber threats continue to increase globally, organisations must implement formal compliance processes to protect systems, information assets, and operational activities.

This document presents the Compliance Documentation Framework developed for the Phoenix Cyber Resilience Project under the Governance & Compliance stream. The framework outlines key security policies, governance procedures, compliance requirements, and monitoring processes necessary to support secure project operations and improve cyber resilience.

The document also aligns with recognised industry standards and cybersecurity frameworks to ensure that the project follows structured governance practices while maintaining accountability, transparency, and operational security.

2. PURPOSE OF COMPLIANCE DOCUMENTATION

Compliance documentation provides a structured approach for defining security expectations, operational procedures, and governance responsibilities within the project environment. Proper documentation supports consistency, accountability, and regulatory alignment while reducing security risks.

The main purposes of this framework include:

- Supporting secure and compliant system operations
- Establishing standard security procedures
- Improving accountability and governance oversight
- Assisting with risk management activities
- Supporting audit readiness and evidence collection
- Ensuring alignment with recognised cybersecurity standards
- Improving organisational resilience during incidents

Well-maintained compliance documentation also assists team members in understanding their security responsibilities and operational expectations within the Phoenix project.

3. GOVERNANCE & COMPLIANCE OBJECTIVES

The Governance & Compliance stream within the Phoenix project focuses on developing policies, procedures, and security controls that support effective cybersecurity management.

Key Objectives

Objective	Description
Security Governance	Establish structured security oversight
Risk Reduction	Minimise cyber security threats and vulnerabilities
Regulatory Compliance	Align with recognised standards and frameworks
Accountability	Define roles and responsibilities
Continuous Improvement	Support ongoing security enhancement

These objectives contribute to the development of a secure, resilient, and professionally managed cyber resilience framework.

4. CYBER SECURITY POLICIES

Policies provide formal guidance on acceptable security practices and operational expectations. The following policies are recommended for the Phoenix project environment.

Core Security Policies

Policy	Purpose
Password Policy	Enforce strong authentication practices
Access Control Policy	Restrict unauthorised access
Incident Response Policy	Guide security incident management
Data Protection Policy	Protect sensitive information assets
Backup & Recovery Policy	Support operational continuity
Acceptable Use Policy	Define appropriate system usage
Document Management Policy	Ensure secure document handling

Each policy should be reviewed periodically to ensure relevance against evolving cyber threats and operational requirements.

5. REGULATORY & STANDARDS ALIGNMENT

Compliance with recognised cybersecurity standards improves governance maturity and supports industry best practices.

Applicable Standards & Frameworks

Framework / Standard	Purpose
ISO/IEC 27001	Information Security Management
NIST Cybersecurity Framework	Cyber risk management guidance
ACSC Essential Eight	Baseline cyber mitigation strategies
Australian Privacy Principles	Privacy and data protection
OWASP Security Guidelines	Secure development practices

The implementation of these frameworks helps ensure that security controls are aligned with internationally recognised governance principles.

6. RISK ASSESSMENT PROCESS

Risk assessment is an important governance activity that assists organisations in identifying and managing cyber security threats.

Proposed Risk Assessment Process

Step 1 Asset Identification

Identify critical systems, services, and information assets.

Step 2 Threat Identification

Identify potential cyber threats such as:

- Phishing
- Malware
- Ransomware
- Insider threats
- Unauthorised access

Step 3 Vulnerability Analysis

Assess weaknesses that may be exploited by attackers.

Step 4 Risk Evaluation

Determine likelihood and impact levels.

Step 5 Risk Mitigation

Implement controls to reduce risk exposure.

Example Risk Matrix

Risk	Likelihood	Impact	Risk Level
Phishing Attack	High	High	Critical
Weak Passwords	Medium	High	High
Data Leakage	Medium	Medium	Moderate
Hardware Failure	Low	Medium	Moderate

Risk assessments should be reviewed regularly as threats and operational conditions change.

7. AUDIT & MONITORING PROCEDURES

Continuous monitoring and auditing are necessary for maintaining compliance and identifying security issues early.

Recommended Monitoring Activities

- Security log monitoring
- User access reviews
- Compliance audits
- Vulnerability scanning
- Backup verification
- Incident tracking

Audit Objectives

Audit Area	Purpose
Access Management	Verify authorised access
Policy Compliance	Ensure policy adherence
Incident Records	Validate response procedures
Backup Systems	Confirm recovery capability

Regular audits improve accountability and help identify areas requiring security improvements.

8. INCIDENT RESPONSE COMPLIANCE

Incident response procedures help organisations manage cyber security incidents effectively while minimising operational disruption.

Incident Response Lifecycle

1. Preparation
2. Detection & Identification
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

Compliance Requirements During Incidents

- Document all incident activities
- Preserve evidence for investigations
- Report incidents to appropriate personnel
- Maintain communication records

- Conduct post-incident reviews

Proper incident documentation supports governance transparency and continuous improvement activities.

9. STAFF ROLES & RESPONSIBILITIES

Clearly defined responsibilities are essential for effective governance and compliance management.

Governance Team Responsibilities

Role	Responsibility
Governance Lead	Oversee compliance activities
Security Analysts	Monitor threats and incidents
System Administrators	Maintain secure infrastructure
Team Members	Follow security procedures

All project participants should contribute to maintaining a secure and compliant operational environment.

10. DOCUMENTATION MANAGEMENT

Secure document management practices improve organisation, accountability, and information protection.

Recommended Practices

- Centralised document repository
- Version control mechanisms
- Restricted editing permissions
- Secure backups
- Document approval workflows

Document Lifecycle

1. Create
2. Review
3. Approve
4. Store
5. Archive
6. Dispose

Proper lifecycle management ensures documentation remains accurate, secure, and accessible when required.

11. RECOMMENDATIONS

The following recommendations are proposed to strengthen governance and compliance within the Phoenix project:

- Conduct periodic compliance reviews
- Introduce mandatory security awareness training
- Implement Multi-Factor Authentication (MFA)
- Maintain regular policy updates
- Improve audit logging capabilities
- Perform scheduled vulnerability assessments

- Establish formal change management procedures

These recommendations will help strengthen operational security and improve long-term cyber resilience.

12. CONCLUSION

The Compliance Documentation Framework developed for the Phoenix Cyber Resilience Project provides a structured governance approach for managing cybersecurity operations, security policies, compliance processes, and organizational responsibilities.

By aligning with recognized standards, implementing formal governance procedures, and maintaining effective documentation practices, the framework supports improved cyber resilience, accountability, and operational security across the project environment.

Continuous monitoring, policy improvement, and staff awareness will remain important for maintaining compliance and adapting to emerging cybersecurity threats.